

# VPN Security Assessment - Executive Summary

Capture: aes128-dh2-transport-pfs-off\_\_web\_run1.pcap | Generated: 2026-09-21 14:32 UTC

**HIGH RISK**

Security score 30 / 100

**In one sentence**

The VPN uses settings that are weak by modern standards and should be changed. The encrypted traffic looks like **web browsing**.

**Important:** the settings below come from the VPN configuration named in the capture's file name (declared by the test setup), not from the traffic itself, because the readable part of the VPN negotiation is not in this capture. Treat the rating as "what was configured", not "what was measured".

## Security settings

| Setting                                                                                                                                                  | Value                   | Rating  | Where the value comes from |
|----------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------|---------|----------------------------|
| Cipher                                                                                                                                                   | AES-CBC-128             | MEDIUM  | Declared by file name      |
| AES-CBC-128 provides confidentiality only — it needs a separate HMAC for integrity, and mis-set integrity checking can open padding-oracle-style issues. |                         |         |                            |
| DH group                                                                                                                                                 | Group 2 (1024-bit MODP) | WEAK    | Declared by file name      |
| 1024-bit MODP is considered too small against modern computing power.                                                                                    |                         |         |                            |
| PFS                                                                                                                                                      | unknown                 | UNKNOWN | Not determinable           |
| Whether Perfect Forward Secrecy is enabled could not be determined from this capture.                                                                    |                         |         |                            |
| Mode                                                                                                                                                     | transport               | MEDIUM  | Declared by file name      |
| Transport mode leaves the original IP header visible; only the payload is encrypted.                                                                     |                         |         |                            |

The score is a weighted average of the rated settings (cipher 40%, key exchange 40%, forward secrecy 20%). Settings that cannot be determined are left out instead of being counted as weak. Mode is shown for information and is not scored.

## Recommended actions

| Priority | Action                                                                                                                                                                 |
|----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| High     | The key-exchange group, Group 2 (1024-bit MODP), is too small for modern threats. Switch to DH group 14 at minimum, preferably an elliptic-curve group (19, 20 or 21). |
| Medium   | Prefer an AES-GCM cipher over AES-CBC-128: it protects integrity as well as confidentiality and needs no separate HMAC.                                                |

|               |                                                                                                                                                                                                      |
|---------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Medium</b> | Confirm in the VPN gateway configuration that Perfect Forward Secrecy is enabled. It cannot be seen in a passive capture.                                                                            |
| <b>Low</b>    | Transport mode leaves the original IP header visible. Use tunnel mode for gateway-to-gateway links unless transport mode is required.                                                                |
| <b>Medium</b> | Repeat the analysis with a capture that includes the IKE negotiation (start the capture before the tunnel comes up), so the settings are read from the traffic itself instead of from the file name. |

## What is travelling through the tunnel

Without decrypting anything, the size and timing pattern of the encrypted packets was matched against five known traffic types. Best match: **Web browsing** (model confidence 100%).

No unusual traffic patterns were flagged.

## What this report cannot tell you

- An IPsec capture only shows the cipher and key-exchange group when the start of the VPN negotiation was captured. Whether forward secrecy is on, and tunnel versus transport mode, are negotiated in an encrypted step and are not visible to an observer.
- The traffic-type label is a statistical guess from packet sizes and timing, trained on five scripted traffic types. It is not proof of what users did.